

可控可信企业智能体白皮书

从“更聪明的AI”到“更可信的AI”

企业级智能体的治理范式、技术架构与商业路径

Agent = Intelligence + Control + Responsibility



可控

Controlled

默认拒绝
显式授权
边界内执行



可信

Trusted

身份可验证
决策可追溯
责任可归属



可审计

Auditable

推理链记录
全过程追踪
持续改进

版本：v1.0

日期：2026 年 6 月

分类：行业白皮书

可控可信企业智能体白皮书

从“更聪明的AI”到“更可信的AI”——企业级智能体的治理范式、技术架构与商业路径

摘要

大语言模型（LLM）的快速演进使智能体（Agent）具备了前所未有的理解、推理和规划能力。然而，企业在将智能体引入核心业务时，面临的根本挑战并非“智能体是否足够聪明”，而是“智能体是否值得信任”。幻觉、不确定性、上下文遗忘、责任归属缺失等 LLM 的天然特性，使未经治理的智能体难以进入企业的关键决策与执行链路。

本白皮书提出一套以“可控可信”为核心的企业级智能体架构与治理模型，核心主张是：

Agent = Intelligence（智能）+ Control（控制）+ Responsibility（责任）

智能体的能力（Ability）与权限（Authority）必须彻底分离。一个真正可被企业信任的智能体，不是“会思考的 LLM”，而是每一次行动都有身份、有依据、有授权、有记录、有责任归属的智能执行体。

本白皮书从市场趋势、治理模型、技术架构、业务场景与商业路径五个维度展开论述，为企业决策者、技术架构师和行业从业者提供一套可落地的理论框架与实践指南。

目录

- [引言：从“大模型”到“小应用”——AI 商业价值的回归](#)
- [核心命题：企业需要的不是智能体，而是受控智能体](#)
- [理论基础：可控智能体的治理模型](#)
- [技术架构：六层运行时模型](#)
- [智能体间治理：从个体控制到组织协同](#)
- [关键业务场景与落地路径](#)
- [商业模式与市场机会](#)
- [结语：可信企业智能体的未来](#)

1. 引言：从“大模型”到“小应用”——AI 商业价值的回归

1.1 市场演进的两个阶段

过去两年，AI 行业经历了清晰的两个阶段：

- **2023–2024：能力建设期**——市场聚焦于“做一个更大的模型”，追求参数规模与基准测试分数的提升。
- **2025–2026：应用爆发期**——市场开始转向“做无数个更小、更垂直、更深入的小应用”，将 AI 能力嵌入具体业务场景。

真正赚钱的机会，已经从“做一个更大的模型”转向“做无数个更小、更垂直、更深入的小应用”。

1.2 大模型正在成为基础设施

大语言模型越来越像电力：

- 没有人因为有电就付钱——人们付钱是因为冰箱、空调、洗衣机、手机。
- 同样，没有人因为 GPT、Claude 或 Gemini 本身而付钱——人们付钱是因为 **AI + 某一个具体场景**：
 - AI 写合同
 - AI 面试助手
 - AI 销售助手
 - AI 采购助手
 - AI 财务助手
 - AI 医疗助手

每一个都是一个数十亿甚至上百亿的市场。

1.3 企业买的是什么？

企业不会买 AI。企业买的是：

降本 或者 增收

- **销售跟进 AI**：自动分析客户沟通、提醒销售、撰写报价、预测成交率——企业愿意年付数十万，因为它直接提升销售额。
- **客服机器人**：100 人客服 → 30 人客服，成本下降 70%，ROI 立即可见。
- **合同审核系统**：AI 检查风险、标红条款、提供修改建议，每份合同节省 30 分钟，一年数万份，价值巨大。

1.4 真正值钱的是 Workflow

AI 产品不等于聊天框。真正产生价值的是完整的工作流：

输入 → AI → 工具 → 数据库 → 审批 → 通知 → 执行 → 反馈 → 继续 AI

AI 只是其中一步，真正赚钱的是整个 Workflow。例如招聘流程：

1.5 五层市场机会

层次	方向	说明
第一层：替代人工	客服、销售、运营、助理、文员、法务、HR	AI ROI 最高的领域，大量重复劳动可被自动化
第二层：提高专业能力	医生助手、律师助手、设计师助手、程序员助手、老师助手	不是替代，而是能力放大
第三层：企业知识	文档、聊天记录、邮件、会议、CRM、ERP 的统一管理与调用	未来几年最大的机会之一
第四层：Agent 协同	销售 Agent、采购 Agent、法务 Agent、HR Agent、研发 Agent 共同工作	管理、记忆、权限、消息流、协同机制
第五层：AI 操作系统	统一调度、统一权限、统一记忆、统一审计、统一成本	企业新的数字基础设施

2. 核心命题：企业需要的不是智能体，而是受控智能体

2.1 两类智能体的根本分野

未来智能体将分化为两类，它们的设计哲学完全不同：

	消费级智能体（Consumer Agent）	可信企业智能体（Trusted Enterprise Agent）
目标	尽可能聪明、尽可能有帮助	在明确边界内完成任务，可审计、可追责、可预测
设计哲学	自由智能	授权智能（Authorized Intelligence）
核心约束	用户满意度	组织规则与治理体系
风险态度	允许试错	默认拒绝（Default Deny）

企业真正信任的，不会是“最聪明的 Agent”，而是“最守规矩的 Agent”。

2.2 LLM 的天然局限

大语言模型有几个天然特性，使其难以直接进入企业核心业务：

- 1. 会幻觉（Hallucination）——生成看似合理但实际错误的信息
- 2. 不稳定（Non-deterministic）——同一个问题答案可能不同
- 3. 会遗忘上下文——长对话中丢失关键约束
- 4. 无法天然承担法律责任——没有法律主体资格
- 5. 很难保证 100% 遵守企业规则——Prompt 不是治理

如果让 Agent 直接执行“收到订单 → 修改 ERP → 付款 → 发货”这样的链路，没有企业敢这么做。不是因为 Agent 不够聪明，而是没有治理。

2.3 从“能力”到“授权”：核心原则重定义

当前行业对 Agent 的技术定义是：

Agent = LLM + Memory + Tools + Planning

但从企业角度，应该重新定义为：

Agent = Intelligence（智能）+ Control（控制）+ Responsibility（责任）

这意味着：

- LLM 提供的是动力，而不是治理——Agent 不是员工，而是马；LLM 像引擎，需要缰绳。
- 能力（Ability）与权限（Authority）必须彻底分离——Agent 不是因为“会”所以去做，而是因为“被授权”才可以做。
- LLM 越聪明，治理层越重要——一个能力极强、能够自动调用几十个系统、还能与其他 Agent 协作的 Agent，如果没有约束，风险指数级上升。

2.4 零信任原则在智能体中的应用

可控企业智能体的底层安全哲学是零信任（Zero Trust）：

Agent 默认没有任何能力，所有能力都是授权获得的。

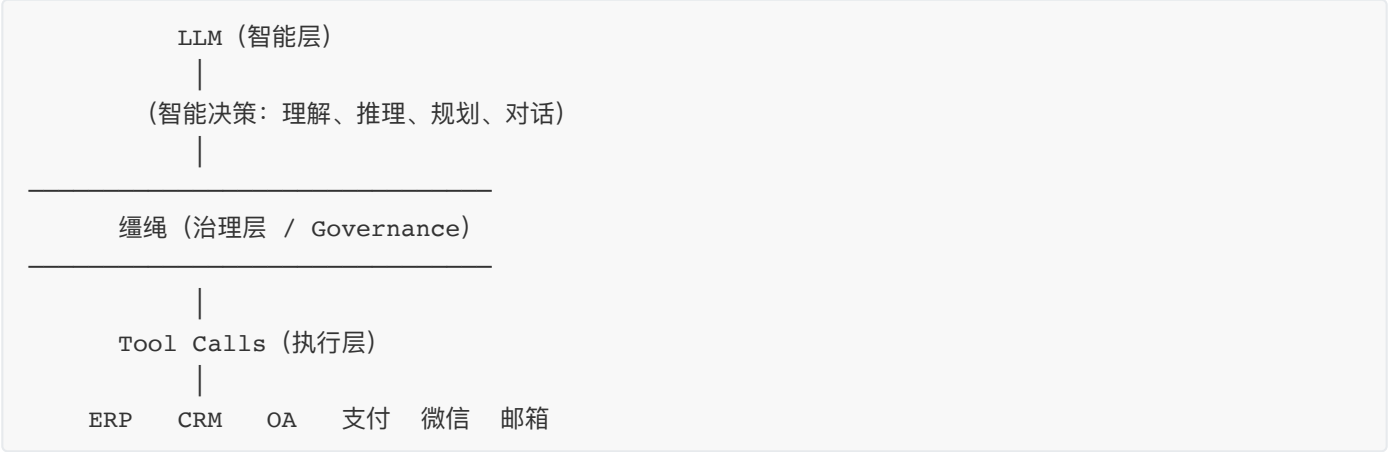
对应四个根本问题：

- 1. 它可以干什么？——Allow List（能力白名单）
 - 2. 它绝对不能干什么？——Deny List（禁止清单）
 - 3. 没有明确授权怎么办？——默认禁止（Default Deny）
 - 4. 它干过什么？——完整决策链追踪（Decision Trace）
-

3. 理论基础：可控智能体的治理模型

3.1 三层架构

将智能体拆分为三个清晰的分层，是理解企业级 Agent 治理的起点：



- **智能层 (Brain)**：由模型厂商（OpenAI、Anthropic、Google、阿里等）提供，负责理解、推理、规划和对话。
- **治理层 (Reins)**：决定 Agent 能干什么、什么时候能干、不能干什么。这一层和 LLM 没有关系，它是纯企业规则引擎。
- **执行层**：真正调用企业系统（ERP、CRM、MES、邮箱、微信、支付等）。

真正控制企业风险的是中间这一层——治理层。

3.2 受控智能体执行模型（CAEM：Controlled Agent Execution Model）

受控智能体执行模型（CAEM）包含四条不可妥协的原则：

原则一：Default Deny（默认拒绝）

任何未明确授权的能力，一律禁止执行。Agent 不能因为“AI 觉得这样更方便”而执行未授权的操作。

原则二：Explicit Capability（显式能力）

Agent 只能执行能力清单中的动作。每项能力都可以配置：

- 权限要求
- 适用条件
- 审批要求
- 可调用系统

原则三：Decision Trace（决策链追踪）

不仅记录执行了什么，更记录：

- 为什么这样理解？
- 如何规划？

- 依据哪些事实？
- 如何评估风险？
- 最终如何验证结果？

这比传统 API 日志更深层——它记录的是**推理链（Reasoning Log）**，而非仅仅是**操作日志（Action Log）**。

原则四：Human Accountability（人类最终负责）

对于高风险或超出授权范围的行动，必须进入人工审批。Agent 永远不能绕过这一环节。最终的责任人始终是人。

3.3 治理六层级

治理不是一根单一的“缰绳”，而是一套完整的控制系统：

层级	名称	核心问题	示例
第一层	Rule（规则）	固定边界是什么？	付款不能超过 50 万
第二层	Policy（策略）	业务条件是什么？	VIP 客户可以优惠 10%，否则不能优惠
第三层	Permission（权限）	数据访问边界？	销售 Agent 不能修改财务数据
第四层	Verification（验证）	事实是否可信？	Agent 说库存 100 件 → 去 ERP 验证
第五层	Approval（审批）	是否需要人工确认？	高风险操作必须老板点击批准
第六层	Rollback（回滚）	执行错误怎么办？	自动恢复操作，撤销错误执行

3.4 决策链审计的四层模型

审计不是记录 API 调用，而是记录完整的推理链：

第一层：Think（思考）

- Agent 为什么这么理解？
- 例：用户说“尽快发货” → Agent 理解为“优先级 = P1”，记录此理解依据。

第二层：Plan（规划）

- Agent 制定了怎样的执行计划？
- 例：① 查询库存 → ② 查询物流 → ③ 修改订单 → ④ 通知客户

第三层：Action（执行）

- 具体调用了哪些系统？
- 例：调用 ERP 查询库存、调用 CRM 更新状态、发送邮件通知

第四层：Evaluate（评估）

- 执行后是否成功？如果失败，为什么？是否需要重新规划？
- 这个迭代过程也完整记录。

3.5 七个不可回避的问题

任何一次 Action 都必须能够回答：

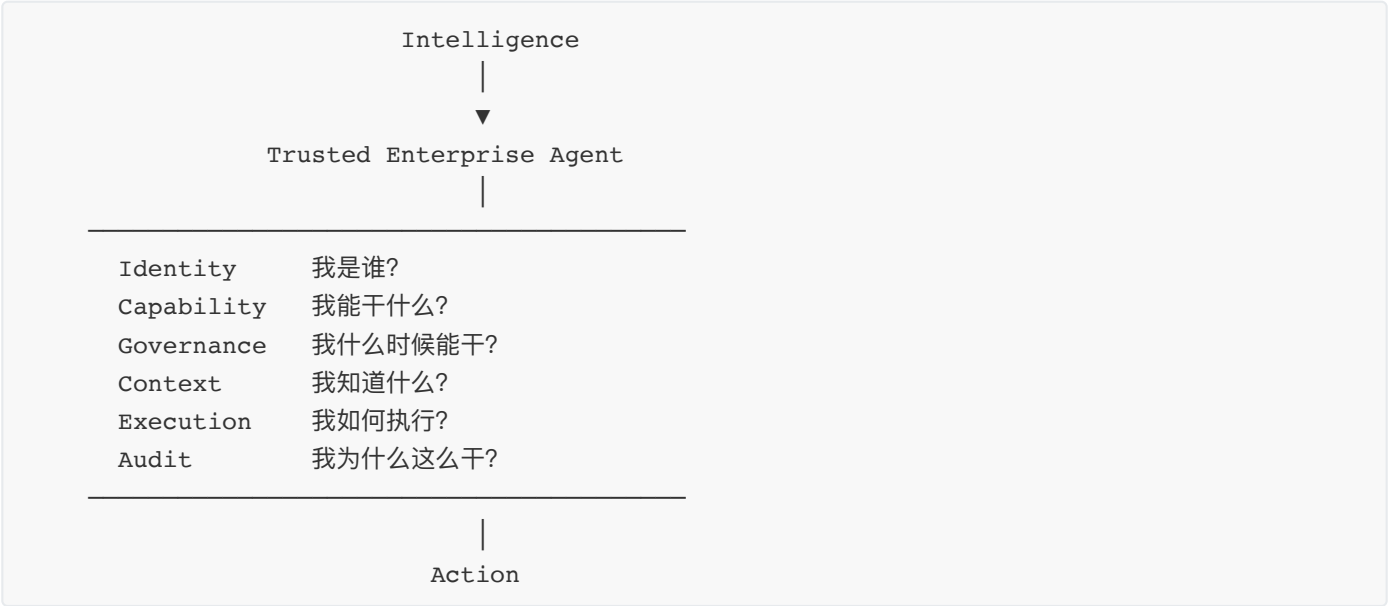
1. **Who** —— 是谁？（Identity）
2. **Why** —— 为什么要做？（Task / Intent）
3. **What** —— 准备做什么？（Capability）
4. **Based on What** —— 依据什么信息？（Context）
5. **Who Approved** —— 谁授权、谁批准？（Governance）
6. **What Happened** —— 最终执行了什么？（Execution）
7. **How Do We Prove It** —— 事后如何证明全过程？（Audit）

如果一个系统能完整回答这七个问题，那么这个 **Agent** 就已经具备了企业级“可控智能体”的基本特征。

4. 技术架构：六层运行时模型

4.1 完整模型

一个可信企业智能体的完整生命周期包含六层：



4.2 各层详细定义

第一层：Identity（身份）

核心问题：我是谁？

采购Agent

部门：采购部

负责人：采购经理

代表：采购部门

工号：AGT-PUR-001

可信等级：L2

没有身份就没有权限。每个可信企业智能体都应拥有类似企业员工的“数字工牌”，包含：Agent ID、所属组织、所属部门、角色、能力范围、权限等级、最高密级、可信等级、可调用工具、审计策略。

第二层：Capability（能力）

核心问题：我能干什么？不能干什么？

- ✓ 查询库存
- ✓ 创建采购订单
- ✓ 查询供应商信息
- ✓ 起草合同
- × 删除订单
- × 修改工资
- × 删除数据库
- × 修改权限
- × 删除日志

能力必须是显式声明的白名单，而不是依赖 Prompt 指令。Forbidden Action 永远不能执行。

第三层：Governance（治理）

核心问题：我什么时候能干？

治理不再是和 Capability、Audit 平级的一个模块，而是贯穿整个运行过程的控制平面（Control Plane）：

```
Governance
├── Policy（策略）：金额 > 100 万必须审批
├── Permission（权限）：销售 Agent 不能访问工资数据
├── Approval（审批）：高风险操作需人工确认
├── Communication（通信）：Agent 间通信需要权限
├── Information Classification（信息分级）：L0-L4 密级控制
├── Risk Control（风险）：异常行为检测和拦截
└── Delegation（授权）：临时授权令牌，有时效限制
```

第四层：Context（上下文）

核心问题：我知道什么？

Agent 不是知道所有东西，而是根据身份和权限获得有边界的上下文：

- 哪些信息？（数据范围）
- 哪些历史？（对话/决策历史）
- 哪些知识？（企业知识库）
- 哪些密级？（信息可见性）

例：采购 Agent 不知道工资；HR Agent 不知道采购价格。同一个问题，不同 Agent 基于不同的上下文获得不同粒度的回答。

第五层：Execution（执行）

核心问题：我如何执行？

执行层是 Agent 真正调用企业系统的环节：

- 调用 ERP / SAP
- 调用 CRM
- 发送邮件 / 微信

- 执行支付
- 操作机器人

所有执行动作必须受 Governance 层控制，任何超出授权范围的操作被实时拦截。

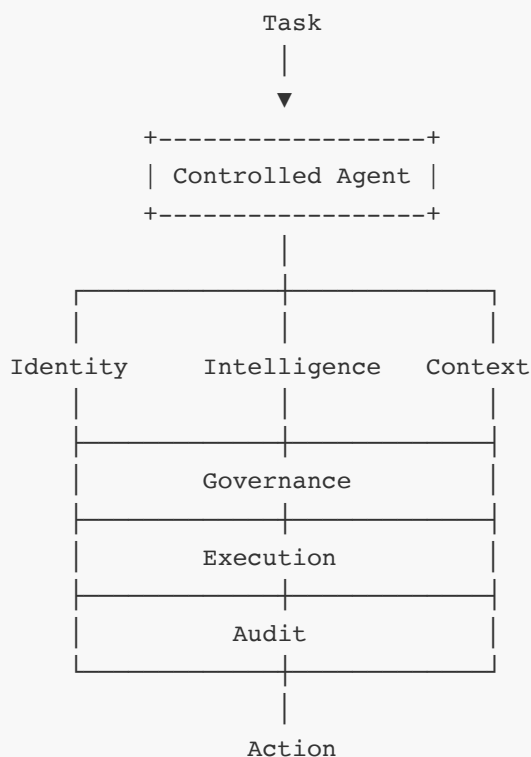
第六层：Audit（审计）

核心问题：我为什么这么干？

审计记录的不是 API 日志，而是完整的 Decision Trace：

依据：采购订单 PO20260012
为什么认为可以付款？→ 合同已审批
为什么认为金额正确？→ ERP 返回 100 万元
为什么调用支付接口？→ 付款条件满足
最终执行：成功

4.3 架构总览



核心设计理念：**Intelligence** 不是中心，**Action**（行动）才是中心。所有模块都为控制 **Action** 而服务。
Governance 作为控制平面贯穿整个生命周期。

5. 智能体间治理：从个体控制到组织协同

5.1 从“网络治理”到“组织治理”

当企业拥有数十个甚至数百个 Agent 时，治理问题从“单个 Agent 能否被信任”扩展为“Agent 群体能否像组织一样运作”。

企业真正的运行逻辑是**组织**，而组织最大的特点是：

信息是不对称的。并不是所有人都应该知道所有事情。**Agent** 也一样。

Agent 之间不应是平等的“网络治理”模式（Agent A ↔ Agent B），而应引入**组织治理**——不同 Agent 基于其角色、部门、权限等级获得不同粒度的信息和不同的通信权限。

5.2 Agent 通信的三层权限

第一层：能不能通信（Communication Permission）

采购Agent → × → CEO Agent（不能直接访问）
采购Agent → √ → 采购主管Agent → CEO Agent（通过组织层级）

第二层：可以看什么（Visibility）

库存Agent 已知：A仓 100，B仓 200，C仓 50
采购Agent 可见：可采购库存 350（脱敏后的聚合信息）

第三层：可以知道多少（Depth）

CEO Agent 问财务Agent：为什么现金流下降？
→ 回答：供应商付款增加，客户回款减少，预计两个月恢复

采购Agent 问同样问题：
→ 回答：现金流正常，无需采购关注（原因完全隐藏）

同一个问题，不同 **Agent**，得到不同答案。

5.3 信息分级体系

等级	定义	可见范围	示例
L0	公开信息	所有 Agent	产品目录
L1	部门共享	特定部门体系	销售数据
L2	管理层	管理层及以上	利润、预算
L3	核心机密	极少数授权者	收购、融资、裁员

每次 Agent 通信，先判断：请求 Agent → 权限 → 信息等级 → 是否允许 → 允许多少 → 返回。

5.4 结构化通信协议

未来 Agent 之间传递的不应是自然语言，而是授权后的上下文：

```
{
  "request": "inventory_query",
  "scope": "purchase",
  "clearance": "L1",
  "reason": "prepare_po",
  "timestamp": "2026-06-29T10:30:00Z"
}
```

接收 Agent 根据 `reason`、`scope`、权限、组织归属来决定返回什么信息，而不是 LLM 随意回答。

5.5 临时授权令牌（Delegation Token）

当高层 Agent 委派任务时，不应永久提升被委派者的权限，而应颁发有时效的临时授权令牌：

授权人：CEO Agent

任务：供应商风险分析

权限：读取 L2 供应商数据

有效期：30 分钟

不可转授权

不可执行付款

30 分钟后权限自动失效，Agent 恢复原有权限。这比永久提升权限安全得多。

5.6 Agent 间治理的七层模型

层	治理内容	核心问题
Identity	Agent 身份	你是谁？
Capability	能力白名单	你能做什么？
Authorization	授权机制	谁允许你做？
Communication	Agent 通信控制	你可以和谁沟通？
Information Clearance	信息分级	你可以知道多少？
Decision Trace	决策审计	为什么这么决定？
Execution Control	执行控制	谁批准最终执行？

5.7 会议范式的变革：从人开会到 Agent 开会

企业会议正经历范式变革：

- 第一阶段（已发生）：Agent 作为会议秘书——录音、纪要、任务分发。

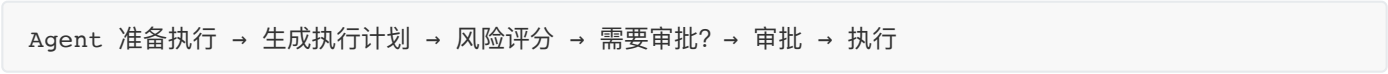
- **第二阶段（未来 2-5 年）**：Agent 参与决策——实时拉取数据、分析、提供建议。
- **第三阶段（未来 5-10 年）**：Agent 代表部门参会——采购 Agent、生产 Agent、销售 Agent、物流 Agent、财务 Agent 同步协商，CEO 只负责批准。
- **第四阶段（未来）**：Agent 自己开会——每天凌晨，上千个 Agent 自动协调当日计划，老板醒来只收到“今日经营建议”。

会议本身将从一种同步沟通方式，演变成一种可计算、可追踪、可自动执行的决策流程。

6. 关键业务场景与落地路径

6.1 场景一：Agent 审批中心（最容易落地）

企业最大的担心不是 Agent 回答错，而是 Agent 执行错。Agent 审批中心作为独立产品：



- 价值：让企业对 Agent 的行动有最终的“刹车”机制
- 切入点：所有企业都有审批流程，天然理解
- 产品形态：Enterprise AI Action Gateway（企业 AI 行动网关）——不是聊天平台，不是 Agent 开发平台，而是企业所有 AI 行动的最后一道关口

6.2 场景二：Agent 操作审计

未来一个 Agent 每天可能调用 ERP 200 次、CRM 300 次、数据库 1000 次。出了问题，必须知道：

- 哪个 Agent?
- 什么时候?
- 为什么?
- 调用什么工具?
- 输入什么? 输出什么?
- 结果如何?

类似数据库审计，但对象从“数据库操作”变成了“Agent 决策与执行”。

6.3 场景三：Agent 权限管理（Agent IAM）

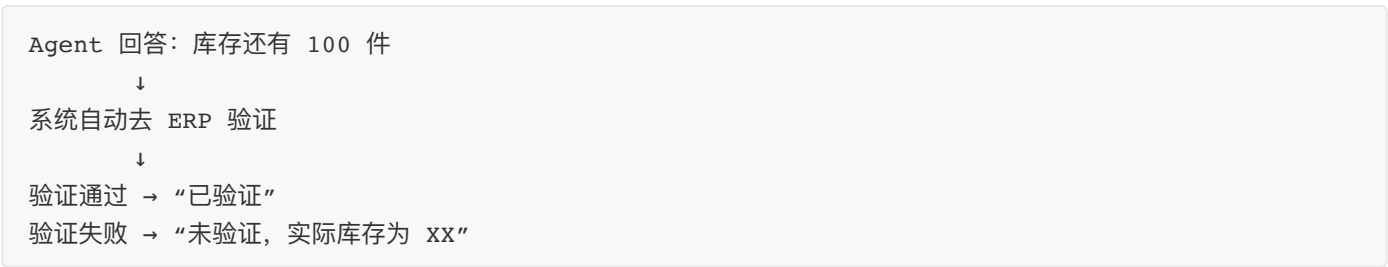
将企业成熟的 RBAC（基于角色的访问控制）体系移植到 Agent：

- 销售 Agent：不能删除订单、不能查看工资
- 采购 Agent：不能付款
- 法务 Agent：不能修改生产计划

对象从“人”变成“Agent”，但权限管理的思想一脉相承。

6.4 场景四：Agent 验证引擎

Agent 不能直接输出结论——必须先经过验证：



这意味着 **Agent** 的输出永远有事实来源作为支撑，而不是依赖 LLM 的概率性生成。

6.5 场景五：Agent 协作调度

当企业拥有 100 个 Agent，极易出现：

- 两个 Agent 互相调用，无限循环
- 多个 Agent 互相覆盖数据
- 资源争用和优先级冲突

需要一个 **Coordinator**（调度器）统一管理 Agent 间的通信、任务分配和资源协调。

6.6 场景六：Agent 决策复盘

Agent 昨天建议采购 1000 台，今天发现错了。系统自动分析：

- 为什么错？
- 依据了哪些信息？
- 哪个知识过期？
- 哪个 Tool 失败？
- Prompt 问题还是模型问题？

然后自动更新规则，让未来越来越准。这不是简单的日志，而是企业级 **Agent** 的持续改进机制。

6.7 场景七：企业间 Agent 协作（B2B Agent）

当 Agent 治理从企业内部扩展到企业之间，会出现更大的市场：

- **采购 Agent** 向 20 家供应商 Agent 自动询价、比较、推荐最优方案
- **供应链 Agent** 在需求变化时自动同步整个供应链，重新排产、重新安排物流
- **物流 Agent** 自动协调货代、船公司、保险、仓储、报关、清关、运输

未来需要的是一套 **Enterprise Agent Network**（企业 Agent 网络）——像互联网一样，每家公司的 Agent 能够安全、可信地互相通信和协作。

7. 商业模式与市场机会

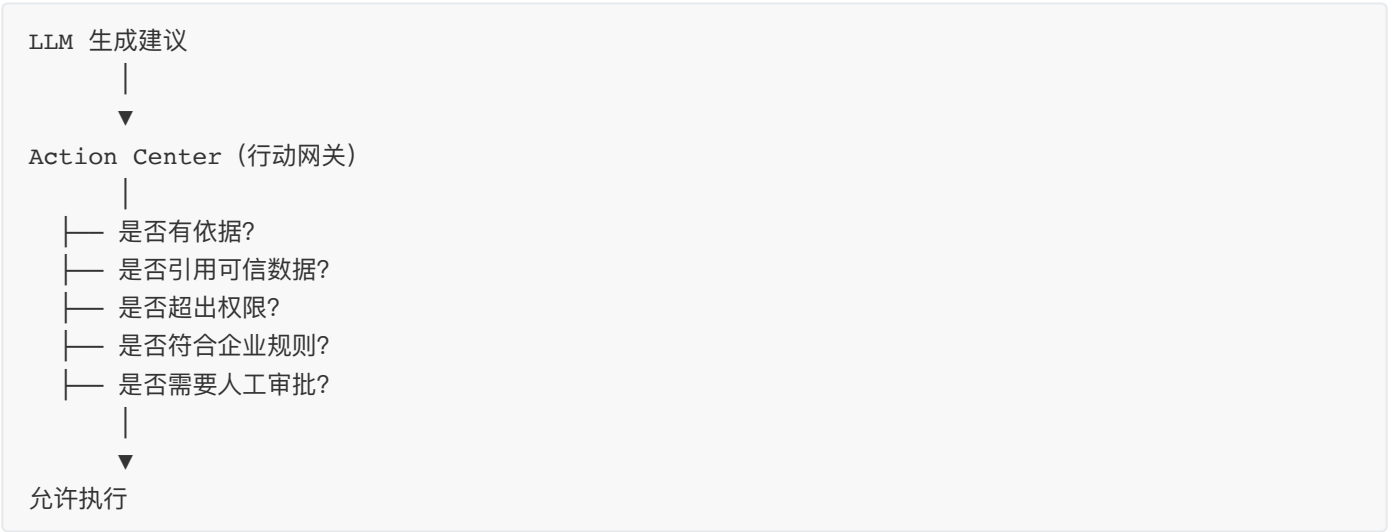
7.1 不做“Agent 治理”，做“治理 for XXX”

正确的切入策略不是做一个抽象的“Agent 治理平台”，而是围绕一个高价值业务场景，把治理做到极致。

正如安全行业：没有人买“网络安全”，大家买的是防火墙、堡垒机、数据库审计、漏洞扫描——最后这些产品共同组成了“安全体系”。

7.2 推荐切入点：Enterprise AI Action Gateway（企业 AI 行动网关）

定位：



核心优势：

- **业务价值直接**：企业关心“能不能安全执行”，而不是模型参数
- **模型无关**：无论是 GPT、Claude 还是 Qwen，都经过同一个 Action Center
- **天然符合企业采购逻辑**：作为 ERP、CRM、OA 前面的“智能执行网关”，不替换现有系统

一句话定位：“你们不是卖 AI，你们是在确保 AI 不会做错事。”

7.3 三个值得长期投入的方向

1. **AI 消息中枢**：连接不同大模型，沉淀聊天、会议、邮件、文档等上下文，形成企业的长期记忆资产。价值的核心在于**持续积累的上下文**。
2. **Agent 管理平台**：随着企业 Agent 数量增加，提供调度、权限、监控、成本控制和协同能力。价值的核心在于**组织化治理**。
3. **行业工作流产品**：围绕一个高价值业务流程，把 AI、工具调用、审批、知识库和自动执行整合成完整解决方案。价值的核心在于**行业深度**。

这三个方向的特点：价值来自持续积累的数据、流程和组织经验，而不是单次调用某个大模型。

7.4 市场分层：按行业切入

行业	典型小应用	年市场规模估算
餐饮	AI 排班	数十亿
医院	AI 病历整理	数百亿
建筑	AI 工程日报	数十亿
外贸	AI 询盘回复	数十亿
教培	AI 作业批改	数百亿
制造	AI 巡检报告	数百亿
电商	AI 商品上架	数十亿
房地产	AI 带看总结	数十亿

关键不是 AI，而是把行业流程、数据和业务规则真正融入产品。

7.5 下一代基础设施：Agent 互联网

如果企业之间通过 Agent 完成大量标准化协作，就会出现一整套新的基础设施需求：

Agent 身份认证 → Agent 权限 → 可信身份 → 数字签名
→ 合同确认 → 支付 → 日志 → 审计

- 第一阶段：网页互联（浏览器访问网站）
- 第二阶段：API 互联（系统调用系统）
- 第三阶段：Agent 互联（组织之间的智能协作）

最大的商业机会未必是开发更多单点 Agent，而是成为 Agent 之间的连接层：定义协作协议、身份认证、权限体系、上下文共享和流程编排。

8. 结语：可信企业智能体的未来

8.1 核心论断

本白皮书从市场趋势、治理模型、技术架构、商业路径四个维度，论证了以下核心论断：

1. **AI 的商业价值不在模型本身，而在“模型 + 具体场景 + 工作流”**。大模型是基础设施，小应用才是价值载体。
2. **企业需要的不是“聪明的 Agent”，而是“可信的 Agent”**。LLM 提供的是动力，不是治理。智能越强，治理越重要。
3. **可控可信企业智能体的核心是：能力与权限分离、默认拒绝、决策链追踪、人类最终负责**。这四条原则构成了 Agent 治理的最小理论模型（CAEM）。
4. **治理不是 Agent 的附属模块，而是贯穿整个运行生命周期的控制平面**。Identity → Capability → Governance → Context → Execution → Audit 六层架构是企业级 Agent 运行时的完整蓝图。
5. **Agent 间的治理需要引入组织级的信息不对称**。通信权限、信息可见性、密级分级、临时授权令牌——这些机制让 Agent 群体像组织一样运作，而不是自由通信的网络节点。
6. **商业路径应聚焦“治理 for XXX”而非“Agent 治理平台”**。以 Enterprise AI Action Gateway 为切入点，围绕审批、审计、权限、验证、协作、决策复盘等具体场景单点突破。

8.2 未来展望

未来几年，最有商业价值的 AI 产品不会是“最聪明的 AI”，而是**最懂某个行业、最能融入企业工作流、最能持续积累上下文、最能让企业放心把关键业务交给它完成的 AI 应用**。

大模型负责提供智能，而可控可信的产品架构负责把智能转化为**稳定、可衡量、可持续的商业价值**。

企业管理的将不再只是“员工”，而是**“员工 + 受控智能体”**：

销售部

销售经理（人）

销售 Agent 01（数字员工）

销售 Agent 02（数字员工）

销售 Agent 03（数字员工）

这些 Agent 拥有工号、权限、部门、直属主管、审批人、生命周期——和正式员工几乎一样。它们不是因为“聪明”而被雇佣，而是因为**可以被信任**。

未来真正重要的不是**“Agent 能做什么”**，而是**“Agent 被允许做什么，以及如何证明它做得对”**。

附录：关键术语表

术语	英文	定义
可控智能体	Controlled Agent	在明确边界内完成任务，且可审计、可追责、可预测的智能体
可信企业智能体	Trusted Enterprise Agent	企业敢把关键业务交给它完成的智能体，满足身份、能力、信息、决策、执行、责任六项可信要求
受控智能体执行模型	CAEM (Controlled Agent Execution Model)	以 Default Deny、Explicit Capability、Decision Trace、Human Accountability 为核心的四原则治理模型
决策链追踪	Decision Trace	不仅记录执行了什么，更记录为什么这样理解、如何规划、依据哪些事实、如何验证的完整推理链
企业 AI 行动网关	Enterprise AI Action Gateway	企业所有 AI 行动的最后一道关口，在 LLM 建议与最终执行之间提供治理、审批、验证和审计
临时授权令牌	Delegation Token	有时效、有范围、不可转授权的临时权限凭证
会话密级	Conversation Clearance	Agent 间每次通信的密级标签，决定接收方可以返回什么信息以及多少信息
智能体 IAM	Agent IAM	将企业身份与访问管理（IAM）体系移植到 Agent 领域的治理框架

版本: v1.0

日期: 2026 年 6 月

出品方: 公众号 技术人进化社

联系邮箱: 2819699195@qq.com

许可: 本文档仅供行业交流与研究参考, 引用请注明出处。